

Technical, security and preliminary impact assessment dossier

Library withdrawal reservation system

Organisation: Biblioteca statale Stelio Crise

Application: Gestione Scarto Librario for WordPress

Version assessed: 9.4.3 release candidate, database schema 8.15

Document date: 19 August 2026

Service page: <https://bibliotecacrise.cultura.gov.it/scarto-librario/>

Privacy notice: <https://bibliotecacrise.cultura.gov.it/informativa-privacy-scarto-librario/>

TECHNICAL DOSSIER · INTERNAL WORKING DOCUMENT

Contents

1. Executive summary
2. Scope and method
3. Purpose and data subjects
4. Technical architecture
5. Data contract and visibility
6. User processes
7. Administrative processes
8. Security measures
9. Retention, erasure and portability
10. Recipients and dependencies
11. Threat model
12. Preliminary risk assessment
13. Open decisions for the Controller and DPO
14. Technical improvement plan
15. Concise project history
16. Evidence package for a specialist
17. Approvals

This document is a technical dossier and a working basis for risk analysis and a DPIA. It is not an approved DPIA, does not replace the opinion of the Data Protection Officer (DPO), and does not certify the security of the complete WordPress infrastructure, hosting platform, mail system or records-management systems.

1. Executive summary

The plugin publishes the catalogue of library items selected for withdrawal and allows users to reserve them after verifying their email address. Staff use the WordPress administration area to import the catalogue, create in-person reservations, confirm delivery, cancel requests, resend summaries, generate PDFs, review logs and statistics, manage data-subject rights and create encrypted backups.

The assessed release uses dedicated WordPress capabilities, REST nonces, input validation, prepared queries, InnoDB transactions, rate limiting, temporary OTPs, AES-256-GCM encryption for pending requests and backups, audit logging and scheduled cleanup. Personal data is not published by catalogue APIs. The plugin's additional security password is stored as a bcrypt hash and not in plaintext.

The principal residual risks concern the security of the whole WordPress site, public enumeration of WordPress user profiles, XML-RPC, privileged accounts without a second factor, WAF and trusted-proxy configuration, copies and exports outside the plugin, dependence on email delivery, and organisational decisions still to be approved concerning legal basis, retention, the blocklist and erasure requests. Two-factor authentication is outside the current operational plan; its absence should be formally recorded as a temporary accepted risk.

2. Scope and method

The assessment covers the PHP and React/TypeScript source, REST schemas, database tables, roles, logs, privacy tools, Excel import, backup functions and the 9.4.3 release candidate. Passive HTTP checks of the public site, which was running the 9.4.2 baseline at the time, were also considered. No exploit, invasive scan, authenticated production assessment, operating-system review, managed-database review, SMTP assessment, supplier-contract review, or complete audit of third-party themes and plugins was performed.

Evidence available on the document date:

- PHP syntax checks passed;
- repository-specific static security checks passed;
- TypeScript and the Vite build passed in the latest release cycle;
- `npm audit` reported no known vulnerabilities in production dependencies;
- passive checks confirmed HTTPS and HSTS and did not expose `.env`, `.git` or `debug.log`;
- items requiring action include enumerable WordPress profiles, enabled XML-RPC, a public `readme.html` and server protections that can be strengthened.

3. Purpose and data subjects

Internal working document - 19/08/2026

3.1 Operational purposes

- make the catalogue of withdrawal items searchable and publicly available;
- receive and verify online reservations;
- record reservations received in person;
- prevent concurrent reservations of the same item;
- communicate the reservation code, summary and status;
- support physical retrieval, delivery and creation of the collection record;
- prevent abuse, reconstruct operations and produce aggregate statistics;
- support access, export, rectification, restriction, erasure or anonymisation;
- provide continuity through backup and restore.

3.2 Categories of data subjects

- people who make or attempt an online reservation;
- people assisted by library staff on site;
- staff and WordPress administrators identified in audit records;
- people placed on the blocklist or subject to a temporary processing restriction.

The Controller and DPO must confirm the purpose, legal basis, necessity and proportionality. The frontend checkbox records acknowledgement of the privacy notice. It should not be described as freely withdrawable consent if processing is based on a task carried out in the public interest.

4. Technical architecture

4.1 Components

- WordPress provides authentication, roles, nonces, cron, mail, options and `$wpdb` database access.
- `gestione-scarto-librario.php` contains bootstrap, schema, migrations, domain logic, REST, OTP and lifecycle functions.
- `includes/security.php` implements origin, payload, session, capability, nonce and private-cache controls.
- `includes/rest-schema.php` declares REST contracts, bounds and request allowlists.
- `includes/admin.php` registers menus, roles, settings and data-subject tools.
- `includes/audit-admin.php` provides logs, filters, CSV exports and statistics.
- `includes/data-tools.php` provides encrypted backups and transactional restore.
- `includes/gdpr-privacy-policy.php` renders the privacy notice through a shortcode.
- `src/index.tsx` and `src/index.css` are frontend sources; Vite produces separate bundles in `dist/`.
- `templates/app.php` renders the public application and applies security headers.

4.2 Flow diagram

Internal working document - 19/08/2026

```
HTTPS visitor
|
+--> WordPress page + public bundle
|   |
|   +--> public REST: catalogue/search/availability
|   +--> reservation POST -> rate limit -> OTP via wp_mail/SMTP
|   +--> OTP confirmation -> InnoDB transaction -> order + items
|
Authenticated WordPress staff
|
+--> wp-admin + administration bundle
|   |
|   +--> capability + WP cookie + X-WP-Nonce + same origin
|   +--> reservations/catalogue/settings/logs/statistics
|   +--> critical actions + plugin security password
|   +--> encrypted backup streamed to the browser
|
WordPress database
+--> catalogue
+--> reservations and reserved-item rows
+--> encrypted temporary OTP payloads
+--> temporary privacy requests with token hashes
+--> pseudonymised rate-limit counters
+--> audit log and options
```

4.3 Declared environment

The target site was described as Linux/Apache, PHP 8.4.11, WordPress 7.0.4, MoneyFlow Child Theme and Elementor 4.2.2. The plugin declares WordPress 6.6 and PHP 8.2 as minimum versions. Compatibility with other plugins, the WAF, caching and SMTP must be tested on the actual site after each relevant update.

5. Data contract and visibility

Dataset	Main data	Visibility	Technical retention
Catalogue	ID, inventory number, author, title, publisher, year, shelf mark, condition, reasons, notes, storage box	public subset; storage box and operational notes restricted	until replacement/reset
Reservation	code, request ID, status, source, dates, name, surname, email or postal address, notice version, IP	authorised staff and data subject through communications/export	according to status and approved policy

Library withdrawal reservation system - v9.4.3 RC

Dataset	Main data	Visibility	Technical retention
Reserved items	title, author, inventory number, storage box, status, collection date	storage box restricted to staff	linked to reservation
Pending OTP	request ID, OTP hash, email hash, encrypted payload, attempts, expiry	system	approximately 15 minutes
Privacy request	email, token hash, action, used flag, expiry	system/privacy staff	approximately 30 minutes, then cleanup
Rate limiting	HMAC of technical key, attempts, expiry	system	abuse-control window
Audit	category, action, outcome, entity, relevant email, WP user, minimised details, IP, User-Agent, time	privacy capability	approved log/IP period
Blocklist	email, concise reason, author, creation, expiry/review	privacy capability	until expiry or review
Processing restriction	email, reason, end date, author and creation	privacy capability	until end/review
Backup	full application archive and settings	privacy staff; encrypted file	external storage policy

5.1 Online reservation

Name, surname, email, selected items and acknowledgement of the privacy notice are required. A postal address is neither accepted nor stored in the online flow. The server detects the IP address. The `User-Agent` is retained only in relevant audit records. The plugin does not fingerprint browsers and does not provide its own advertising or analytics integration.

5.2 In-person reservation

Staff enter name and surname. If a valid email is available, no postal address is collected. If the data subject has no email, street, house number, postcode, town/city and province are required; shipping notes are optional and must contain only necessary instructions. The postal address supports possible delivery of a letter containing the registered document concerning the reservation and handover.

5.3 Published data

Public APIs expose bibliographic information, inventory number, condition and availability/countdown. They do not expose names, email, postal addresses, IP addresses, User-Agent strings, reservation codes, storage-box numbers, logs, backups or diagnostics. WordPress REST route names and schemas can be publicly enumerated by design and must not be treated as secrets.

6. User processes

Internal working document - 19/08/2026

6.1 Catalogue and reservation

1. The user browses or searches the paginated catalogue.
2. Available items are selected; availability is checked again by the server.
3. The user enters name, surname and email and acknowledges the privacy notice.
4. The server validates fields, checks blocklist/restrictions and applies IP/email limits.
5. A six-digit numeric OTP is generated. The pending payload is encrypted and only an OTP hash/HMAC is stored.
6. The user submits the OTP within approximately 15 minutes and within the attempt limit.
7. A transaction locks and rechecks the books, generates a unique code and creates the reservation idempotently.
8. A summary is sent to the data subject and the library according to mail settings.
9. Items remain reserved until collection, cancellation or expiry; the frontend displays status and a server-synchronised countdown.

6.2 Data-subject rights

The public flow can request an export or erasure by proving control of the email account. The initial response is generic to reduce account enumeration. A random token is emailed, stored as a hash and expires. Active reservations block automatic erasure; completed reservations are anonymised, while cancelled/expired records are deleted according to current rules.

This automation is a technical design, not a legal determination. The Controller and DPO must decide whether self-service erasure may have automatic effect or must always be reviewed by authorised staff, considering archival obligations, registered records, legal claims and data in external systems.

7. Administrative processes

7.1 Roles

- **Library Withdrawal Operator:** views and manages reservations and creates in-person requests.
- **Library Withdrawal Manager:** has all plugin capabilities, including catalogue, settings and privacy.
- **WordPress Administrator:** receives all plugin capabilities.

Access should follow least privilege. Named individual accounts are preferable to shared accounts. Removal or role change should include disabling or changing the related WordPress account.

7.2 Main operations

- Excel import with local and server validation, bounded size, a maximum of 50,000 rows, duplicate checks and a transaction;

- catalogue updates preserving reservations, with strengthened confirmation when active reservations exist;
- global paginated search, pending-reservation filter, collection confirmation, cancellation and summary resend;
- in-person creation without OTP or public limits, attributed to the WordPress account;
- collection PDF with item details and signature area;
- filterable/exportable logs, aggregate statistics and CSV export;
- management of the blocklist, institutional allowlist, retention and cleanup;
- data-subject search by email/code, JSON export, rectification, restriction and reasoned erasure/anonymisation;
- complete encrypted backup and validated replacement restore.

Critical actions require a capability, nonce and additional password. Historical code labels this password as a "database password", but it is not the WordPress MySQL credential. It is an application secret whose bcrypt hash is stored in `wp_options`.

8. Security measures

8.1 Authentication and authorisation

- WordPress session and dedicated capabilities for each area;
- `X-WP-Nonce` for administrative REST and WordPress nonces for `admin-post` forms;
- same-origin and `Content-Type: application/json` checks;
- plugin security password for import, reset, retention, privacy and backup actions;
- invalidation of application sessions after password rotation;
- `Secure`, `HttpOnly`, `SameSite=Strict` application cookie where used.

8.2 Integrity and concurrency

- InnoDB operational tables, transactions and `SELECT ... FOR UPDATE`;
- unique `request_id` and idempotent responses for retries/double clicks;
- cryptographically generated reservation code with a unique database constraint;
- availability snapshots and server-side recheck before commit;
- checksum, schema, size and record-count validation during restore.

8.3 Encryption and secrets

- AES-256-GCM encryption for pending OTP payloads, keyed from WordPress salts;
- OTPs, recovery tokens and privacy tokens stored as hashes;
- plugin password stored using bcrypt cost 12;
- AES-256-GCM backups with PBKDF2-HMAC-SHA256 key derivation, random salt and IV;

- the MySQL password remains solely in WordPress `wp-config.php` and is not read or returned by the plugin;
- no SMTP key or credential was found in the assessed release package.

Internal working document · 19/08/2026

8.4 Application security

- REST schemas with types, patterns, bounds and rejection of unexpected fields;
- WordPress sanitisation and context-specific output escaping;
- prepared dynamic queries or internal allowlisted identifiers;
- request-size, row-count, pagination, attempt and rate limits;
- private `no-store` responses; CSP, HSTS, frame protection, `nosniff` and restrictive policies on the service page;
- local runtime assets and fonts, with no plugin telemetry or runtime CDN;
- logs exclude OTPs, passwords, complete payloads and postal addresses from free-form details.

9. Retention, erasure and portability

Technical defaults are 365 days for completed reservations, 90 days for cancelled/expired reservations and audit logs, and 30 days for IP/User-Agent data. These are fallback values and are not evidence of approval. The settings page requires an approval declaration and password before changing them. Cron handles reservation expiry, personal-data cleanup, IP anonymisation, log/counter/temp-file deletion, and exposes last-run time and counts.

Reset deletes the catalogue, reservations, line items, pending OTPs, privacy tokens and counters while retaining settings and audit evidence necessary to document the action. Uninstall retains data unless explicit destructive cleanup is enabled. The backup contains catalogue, orders, items, logs, blocklist, restrictions and settings; it excludes passwords, OTPs, sessions and temporary counters.

Downloaded files, PDFs, email, registered records and paper copies leave the plugin's technical boundary and require separate access, encryption, transfer, retention and destruction rules.

10. Recipients and dependencies

Data may be processed by authorised staff, system administrators, hosting/database providers, mail providers and, where applicable, records-management and postal-delivery systems. The plugin uses `wp_mail` /PHPMailer and cannot guarantee final delivery. The assessed code does not send data to advertising or analytics services.

Contracts, appointments, data locations, subprocessors, non-EEA transfers, infrastructure logs, hosting backups and external retention must be inventoried. Themes, Elementor and other plugins share the PHP process and WordPress privileges and can affect the overall security posture.

11. Threat model

Internal working document · 19/08/2026

11.1 Threat actors and hazardous conditions

- anonymous visitors automating requests, enumerating endpoints or attempting injection;
- users submitting another person's email address or guessing OTPs;
- bots generating traffic and outbound email;
- compromised Operator, Manager or Administrator accounts;
- authorised insiders accessing or exporting data without need;
- manipulated Excel or backup files;
- caches/CDNs retaining private responses;
- vulnerable third-party plugins/themes in the same WordPress installation;
- operational error during import, cleanup, role changes or hardening;
- server/database compromise or theft of a downloaded backup.

11.2 Assets

- identity/contact data, IP/User-Agent and reservation history;
- reservation codes, OTPs and temporary tokens;
- catalogue, status and item availability;
- accounts, capabilities, nonces, WordPress salts and application password;
- logs, blocklist, exports, PDFs and backups;
- service availability, reservation integrity and email reputation.

12. Preliminary risk assessment

Likelihood and impact use a 1 (low) to 5 (very high) scale. Residual risk is a technical estimate for validation by the Controller, DPO and infrastructure operator.

Scenario	Initial L/I	Existing controls	Residual	Required treatment
Privileged account compromise	3/5	WP password, capabilities, nonces, destructive step-up, audit	medium-high	unique passwords, named accounts, login alerts; 2FA deferred and risk recorded
WordPress profile enumeration	4/2	no reservation data exposed	medium	restrict endpoint or separate slug/display/login under anti-lockout procedure
OTP/email abuse	4/3	IP/email limits, blocklist, expiry, generic response	medium	staged WAF, SMTP and 429 monitoring

Library withdrawal reservation system · v9.4.3 RC

Scenario	Initial	Existing controls	Residual	Required treatment
L/I				
Access to administrative REST	3/5	capabilities, nonce, origin and no-store	low-medium	extend no-store coverage to all admin errors
Double booking/concurrency	3/4	InnoDB locks, transactions, unique constraints, idempotency	low	periodic concurrency and storage-engine tests
Database exfiltration	2/5	hosting controls and hashed/encrypted temporary secrets	medium	server hardening, patching, least-privilege DB, protected hosting backups
Backup/export/PDF theft	3/5	encrypted backup and audited download	medium	approved repository, expiry, secure channels, remove local copies
Hostile import	3/4	extension/schema/bounds/sanitisation/transaction	low-medium	malicious-file tests and maintained XLSX dependency
Private response caching	2/4	no-store and CSP	low-medium	add missing admin routes to central filter and test CDN
Blocklist misuse	3/4	concise reason, author, expiry/review, privacy area	medium	approved criteria, notice and documented review
Incorrect retention or stalled cron	3/4	cron, diagnostics and cleanup status	medium	system cron, alerting and monthly check
Uncoordinated erasure	3/4	export/delete, active-record block, audit	medium	Controller/DPO procedure and reconciliation with mail/records/paper
Hardening lockout	3/5	SFTP recovery available	low-medium	enforce the anti-lockout gate in the operational plan
Third-party theme/plugin vulnerability	3/5	updates/hosting, not assessed here	medium-high	inventory, vulnerability scan and whole-site staging

No straightforward anonymous path to personal data or plugin passwords was identified. Unknown vulnerabilities, infrastructure compromise or chains through third-party components cannot be excluded without an authorised penetration test.

13. Open decisions for the Controller and DPO

- confirm legal basis and acknowledgement wording;
- determine whether a formal Article 35 DPIA is required;

Library withdrawal reservation system - V9.4.3 RC

- approve retention and erasure criteria for plugin, mail, registered records, letters and backups;

- confirm necessity of postal address only for in-person reservations without email;
- approve blocklist criteria, duration, information and review;
- decide whether self-service erasure may have automatic effect;
- define identity verification, exceptions and response times for rights;
- identify Controller, authorised persons, processors, system administrators and recipients;
- inventory Apache/WAF/SMTP/hosting logs and transfers;
- define incident response, personal-data-breach handling and escalation contacts;
- record the temporary absence of 2FA and compensating controls.

Internal working document · 19/08/2026

14. Technical improvement plan

Release candidate 9.4.3 completed private no-store coverage, the privacy capability for global purge, correct application-password wording, per-account lockout isolation and default rejection of unencrypted backups. Remaining actions are:

1. install and test 9.4.3 on staging with the full role matrix;
2. limit user enumeration and assess XML-RPC under the anti-lockout procedure;
3. protect `wp-config.php`, disable the file editor and remove `readme.html`;
4. introduce WAF monitoring before gradual enforcement;
5. test concurrency, CDN caching, backup, privacy tools, cron and rollback in real WordPress;
6. commission a whole-installation vulnerability assessment and an authorised penetration test before, or promptly after, a controlled go-live.

15. Concise project history

- **8.7.1-8.8.1:** secured GDPR endpoints, removed PII from debug output, added retention/IP controls, privacy notice and DPO contacts.
- **9.0.0:** moved staff work to `wp-admin`, introduced roles/capabilities, separate bundles, privacy tools and step-up authentication.
- **9.0.1-9.0.7:** abuse/proxy hardening, concurrency controls, Excel import, SMTP diagnostics, accessible condition status, public-data minimisation, countdown and feedback.
- **9.1.0-9.1.3:** logs/statistics, allowlist/blocklist, complete PDFs, availability refreshes and settings preservation.
- **9.2.0-9.2.3:** global pagination/search, log/statistics export, backup/restore, charts and reservation filters.
- **9.3.0-9.3.2:** structured address, in-person reservations, email resend, linked logo, UI validation and catalogue import with active reservations.
- **9.4.0-9.4.2:** comprehensive data-subject tools, structured blocklist, encrypted backup, observable cleanup, source-based email/address rule and corrected online OTP payload.
- **9.4.3:** private cache and privacy capability hardening, per-account lockouts, fail-closed legacy backups and a reproducible ZIP with sensitive-artifact checks.

This history is derived from source version notes and repository plans. It does not replace a signed change record or a complete Git history.

Internal working document · 19/08/2026

16. Evidence package for a specialist

- exact installed ZIP and SHA-256;
- this dossier, operational plan and current privacy notice;
- role/capability matrix and assigned-account list without passwords;
- screenshots of privacy/retention settings, diagnostics and latest cleanup;
- complete version list for WordPress, theme, plugins, PHP, Apache and database;
- redacted WAF/proxy/cron configuration without secrets;
- anonymised examples of logs, data-subject exports, email and PDFs;
- staging backup/restore result;
- anonymous/Operator/Manager/Administrator test results;
- supplier roles/contracts, hosting-backup periods and external-log retention;
- Controller decisions and DPO opinion;
- risk-acceptance register and named action owners.

17. Approvals

Role	Name	Date	Decision/signature
Service owner			
IT/hosting owner			
Controller/delegate			
DPO			
Test owner			

Proposed classification: internal working document. Distribute only to people involved in the assessment and remove attachments containing real personal data before transmission.